



THE UNIVERSITY OF
MELBOURNE

SWEN90010 - High Integrity Systems Engineering

Security Engineering: Threat Modelling

Toby Murray



toby.murray@unimelb.edu.au



DMD 8.17 (Level 8, Doug McDonnell Bldg)



<http://people.eng.unimelb.edu.au/tobym>



@tobycmurray

SECURITY ENGINEERING: THREAT MODELLING (C.F. HAZARD ANALYSIS)

See: Shostack, *Threat modeling: Designing for security*. Wiley, 2014
(Available as an ebook from the library:
library.unimelb.edu.au)

Basic Security Properties:

Confidentiality

Integrity

Availability

Authentication

Non-Repudiation

Access Control



THE UNIVERSITY OF
MELBOURNE

SECURITY DESIGN PRINCIPLES

Saltzer & Schroeder (1975)



THE UNIVERSITY OF
MELBOURNE

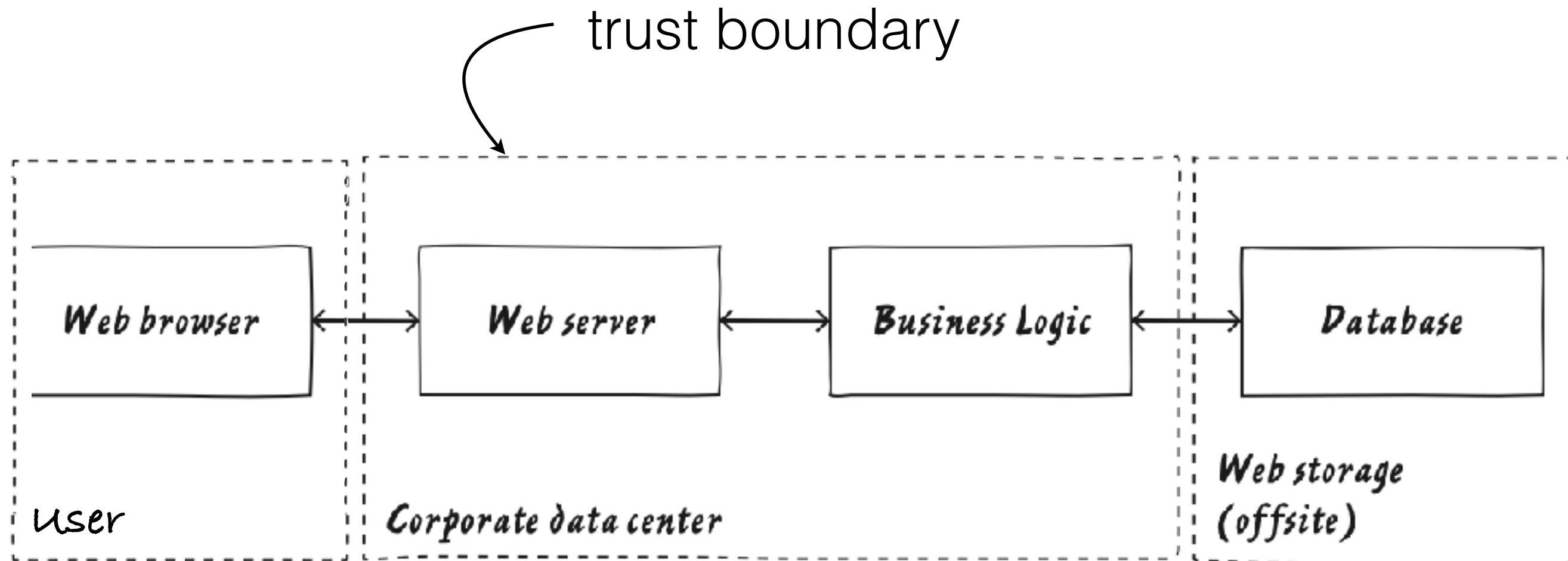
- Economy of Mechanism - complexity breeds insecurity
- Fail-safe defaults - default deny
- Complete mediation - every access needs to be checked
- Open design - do not rely on the attacker's ignorance of your system
- Separation of privilege - privileged actions should require coordination
- Least privilege - every program should have only the privileges needed
- Least common mechanism - minimise code that everyone has to trust
- Psychological acceptability - the easiest way = the most secure way



THE UNIVERSITY OF
MELBOURNE

STRIDE

Threat Modelling



Different parts of the system will be controlled by different entities (e.g. users vs the company vs third-party provider)

A **trust boundary** groups together all components that are under the control of the same entity

STRIDE

- **Spoofing:** pretending to be something or someone you are not
- **Tampering:** modifying something you are not supposed to
- **Repudiation:** claiming you didn't do something
- **Information Disclosure:** revealing information to people who are not supposed to see it
- **Denial of Service:** crashing a system, making it too slow, exhausting its storage
- **Elevation of Privilege:** being able to do something that, technically, you not allowed to do



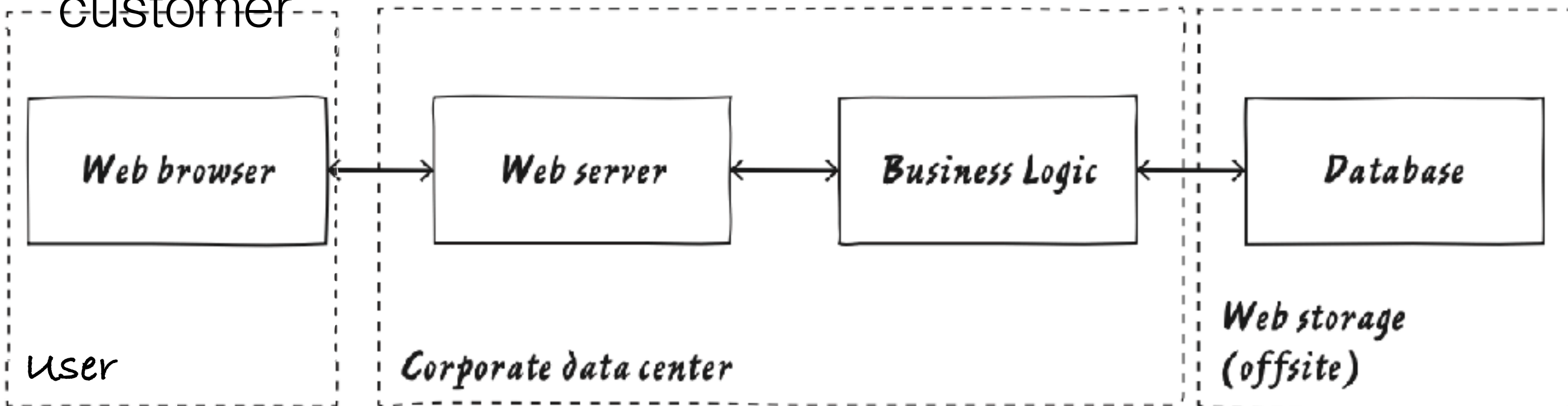
Spoofing

pretending

to be your website
(phishing attack)

pretending

to be another
customer



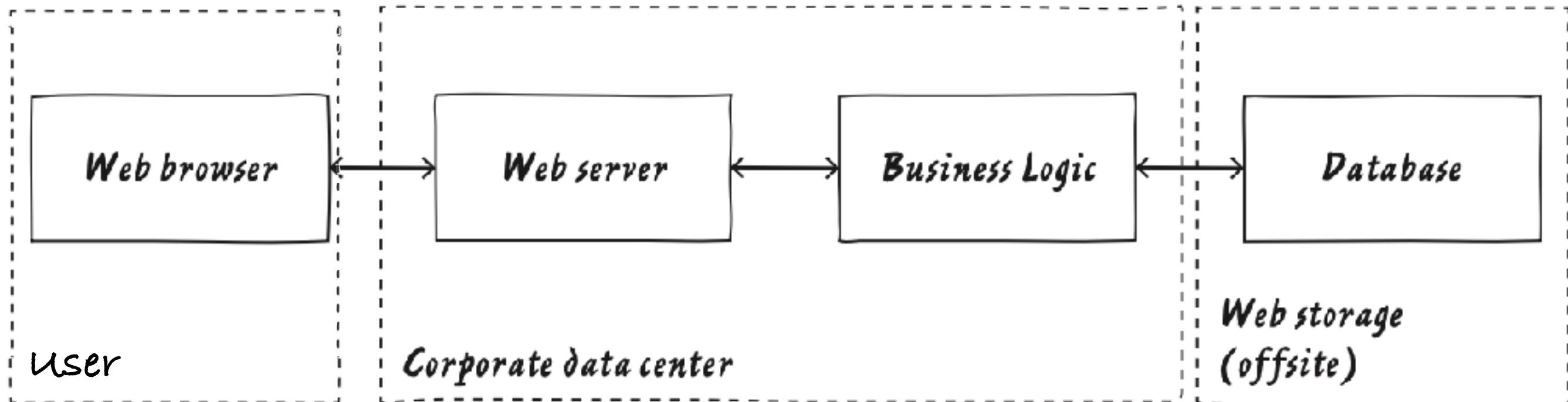
another site forging a
link to one of your pages
(e.g. placeorder.aspx)
(CSRF attack)

Tampering



THE UNIVERSITY OF
MELBOURNE

tampering with
data in transit



website defacement

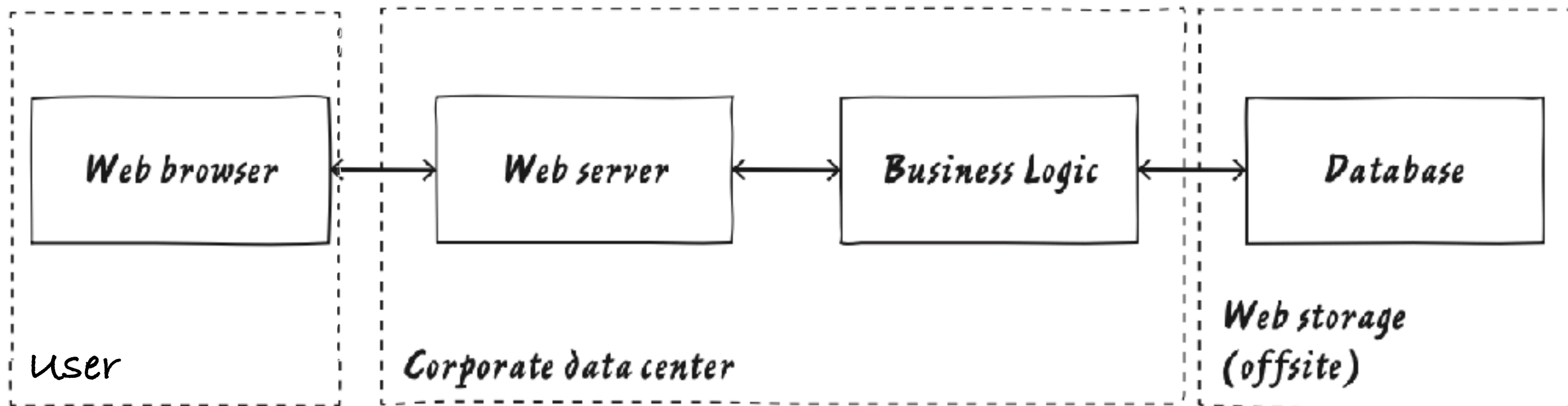
tampering with
database
contents by
offsite admin

Repudiation



THE UNIVERSITY OF
MELBOURNE

are there system logs?



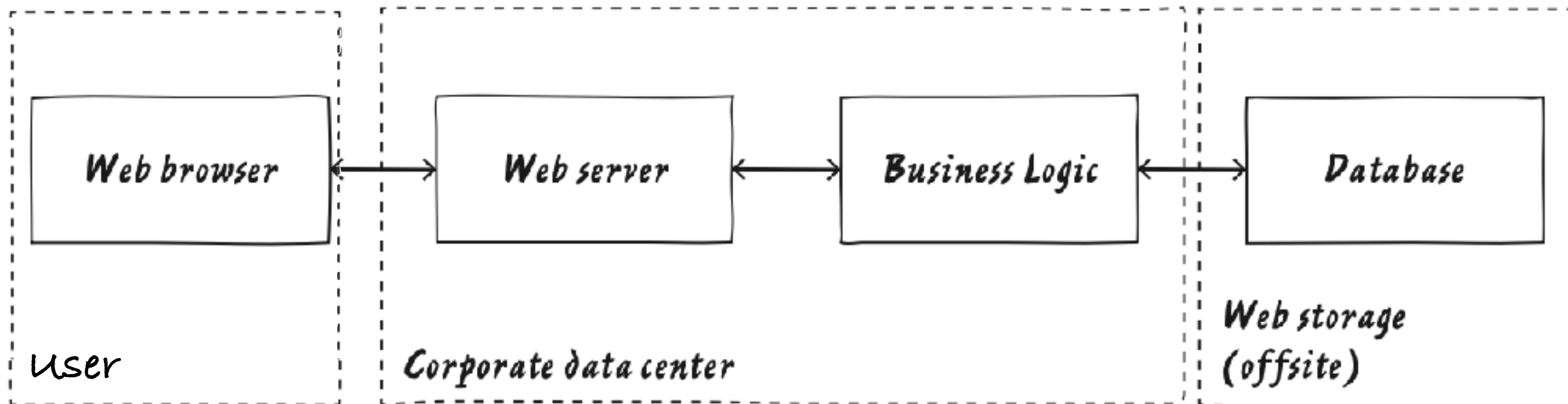
do they log
the right
information?

are they protected
against tampering?

Information Disclosure

SQL injection

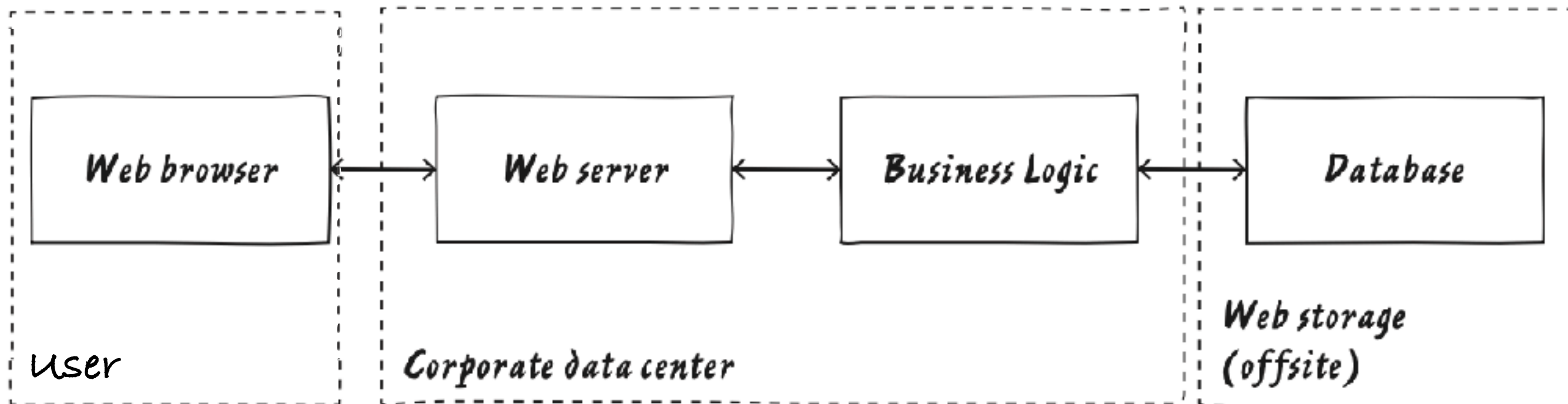
offsite admin
reads database



what if somebody
steals your TLS
private key?

what if somebody steals
your password file?
(is it encrypted?)

Denial of Service



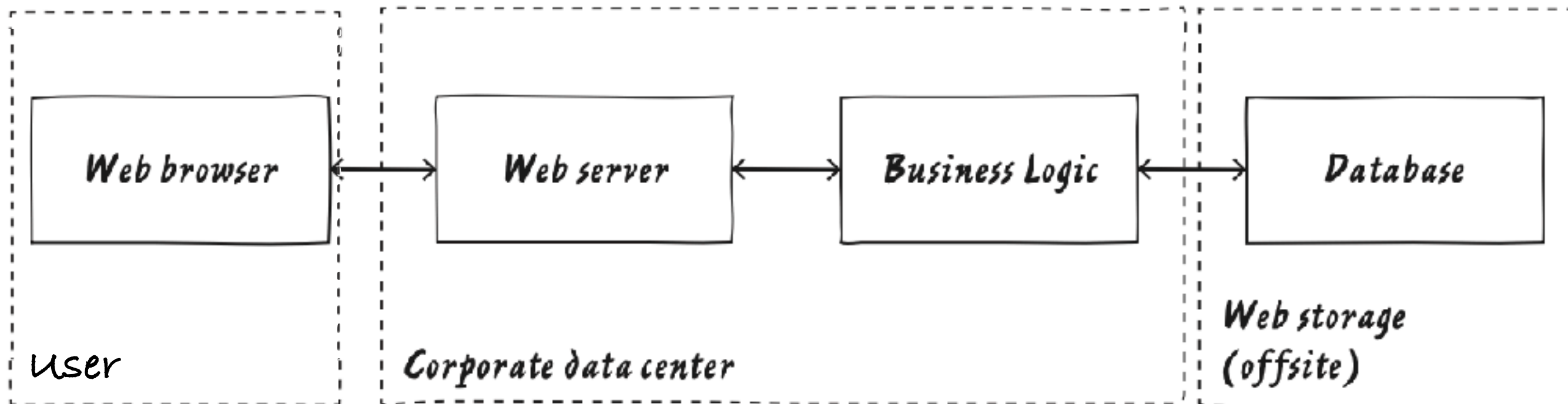
what if your site
gets overwhelmed by traffic?

what if the
offsite db provider
goes down?

Elevation of Privilege



Can they issue web requests for other users' content (e.g. IDOR)?



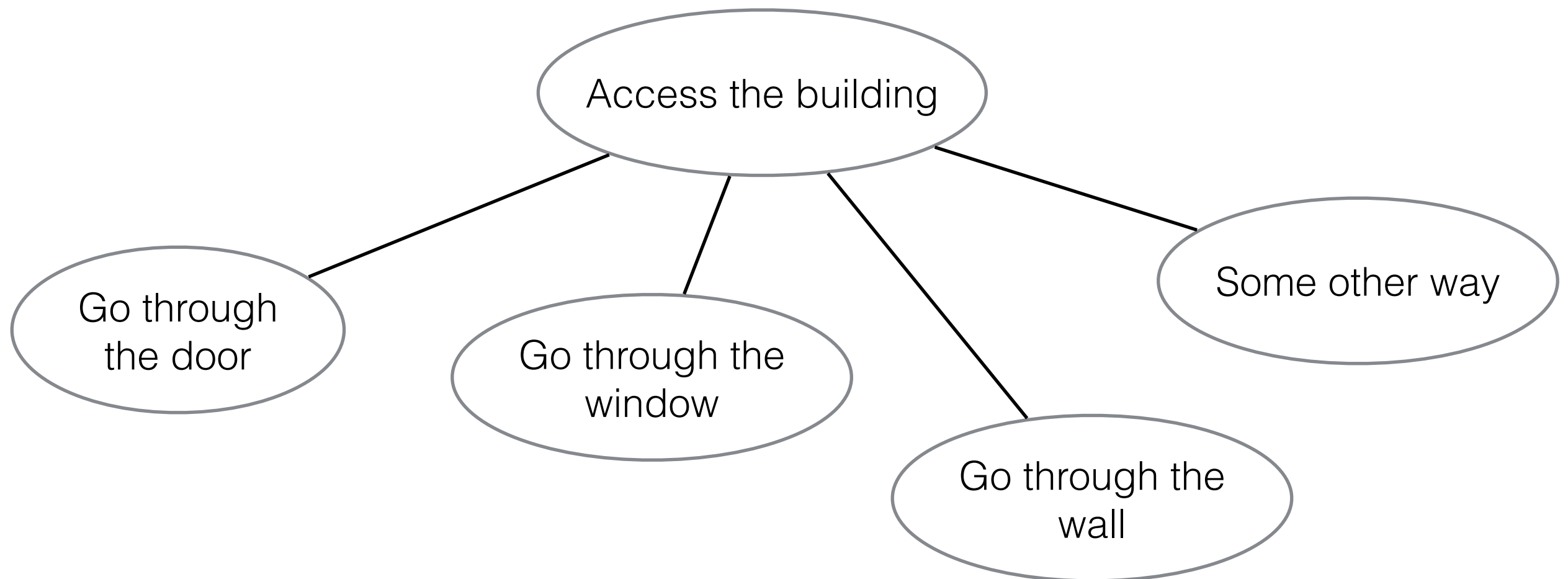
Can customers connect directly to the business logic server?

Can others connect to the offsite db?

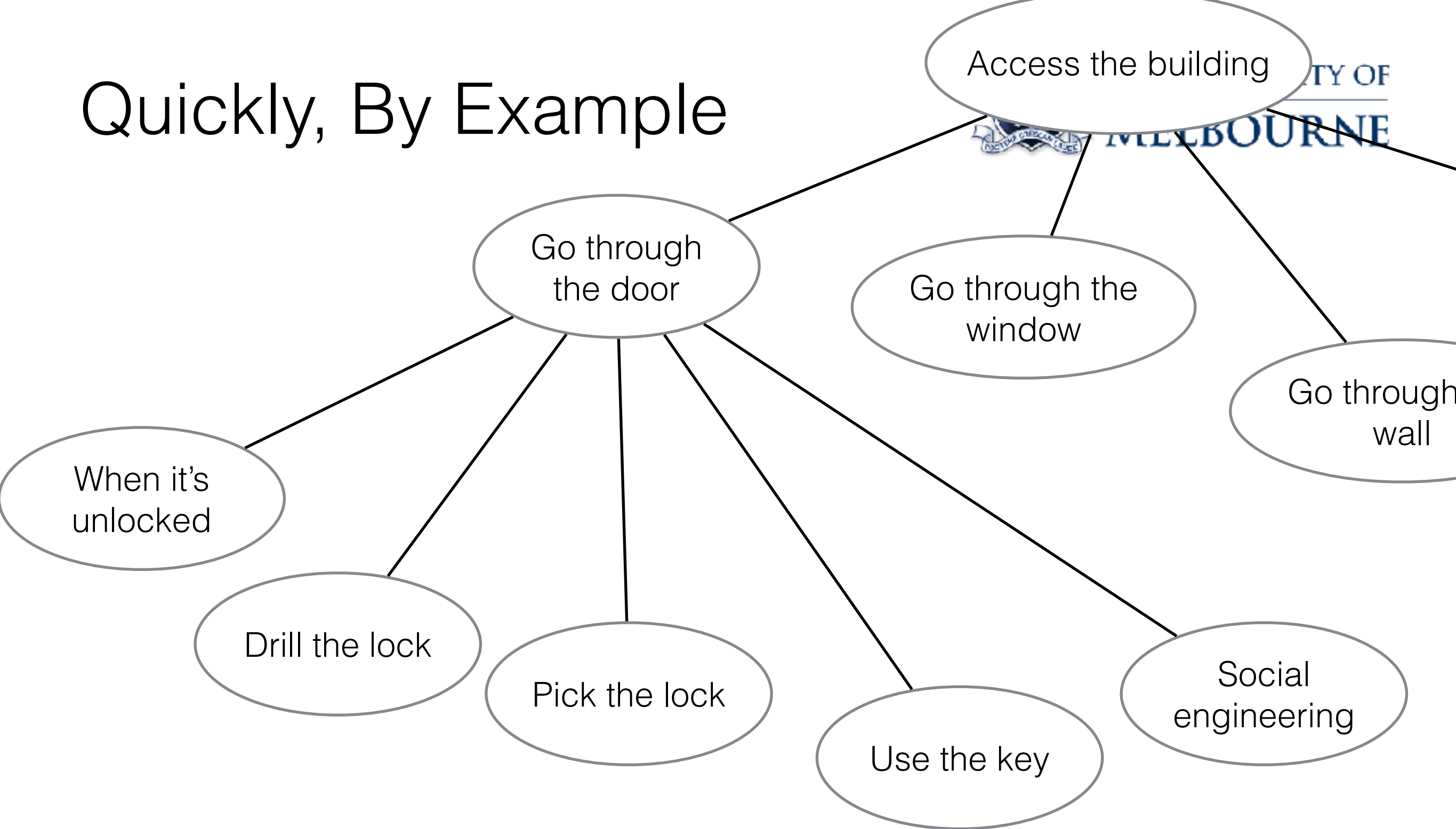


ATTACK TREES

Quickly, By Example



Quickly, By Example





Quickly By Example

Pick the lock

Pick the lock

Social
engineering

Use the key

Go through
wall

Find a key

Steal a key

Photograph
+ reproduce

Social
engineer a key

etc